Política de seguridad, implementación y auditoría

1. La política dentro de la gestión del riesgo

Una **política de seguridad** establece decisiones y obligaciones de una organización para proteger su información y sus servicios. Define a quiénes alcanza, qué conductas y condiciones exige, quién responde por su aplicación y cómo se revisa su cumplimiento. Su autoridad interna depende de una aprobación por el nivel competente y de su comunicación a las personas afectadas.

El análisis de riesgo explica por qué hace falta la política. Si una cuenta permanece activa después de una desvinculación, la organización necesita algo más preciso que «mejorar la seguridad»: debe determinar quién comunica la baja, quién suspende el acceso, en qué plazo y cómo se confirma la suspensión.

La relación con el tratamiento estudiado en la lección 10 puede representarse así:

Elemento	Función	Ejemplo
Riesgo	Describe el escenario y su consecuencia.	Una persona desvinculada utiliza una cuenta aún habilitada para modificar información.
Tratamiento	Selecciona la respuesta al escenario.	Mitigar mediante baja oportuna y revisión de cuentas.
Política	Establece la obligación institucional.	Los accesos deben retirarse al terminar la relación laboral, con responsabilidades y plazos definidos.
Control	Aplica la obligación.	Flujo de notificación de Recursos Humanos y suspensión en el servicio de identidades.
Evidencia	Permite evaluar lo que ocurrió.	Aviso, fecha efectiva de salida, registro de suspensión y conciliación posterior.
Revisión	Determina qué riesgo permanece.	El propietario evalúa atrasos, cobertura y necesidad de nuevas acciones.

Una política puede respaldar varios tratamientos y un riesgo puede necesitar varias políticas y controles. La relación se conserva mediante identificadores y referencias: requisito, escenario, responsable y evidencia deben poder vincularse.

Aprobar la política no reduce automáticamente el riesgo residual actual. La distinción de L10 se mantiene: el residual esperado es una meta condicionada a implementar y verificar; el actual se estima con evidencia de los controles que operan. La calidad de la redacción y la eficacia del control son aspectos relacionados, pero distintos.

2. Política, estándar técnico, procedimiento y registro

La gestión de seguridad utiliza documentos con funciones diferentes. Distinguirlos permite mantener una obligación aunque cambie la herramienta que la ejecuta.

Documento	Pregunta que responde	Ejemplo de acceso remoto
Política	¿Qué se exige y quién responde?	El acceso administrativo debe limitarse a personas, equipos y orígenes autorizados.
Estándar técnico interno	¿Qué condiciones o valores deben cumplirse?	Servicios permitidos, redes autorizadas, mecanismos de autenticación y parámetros de registro.
Procedimiento	¿Cómo se realiza una tarea?	Solicitar acceso, aprobarlo, configurar reglas, probarlas y revertir el cambio si falla.
Registro	¿Qué se hizo y qué resultado tuvo?	Ticket autorizado, configuración final, pruebas y fecha de revisión.

«Ejecutar `ufw allow`» describe una acción técnica. «El administrador debe mantener el acceso restringido a los orígenes autorizados y comprobarlo tras cada cambio» expresa una obligación que podría implementarse con UFW u otro firewall.

El **estándar interno** de la tabla es una especificación de la organización. Un estándar externo, como ISO/IEC 27001, cumple otra función: aporta requisitos para un sistema de gestión dentro de su alcance. Un marco, un catálogo de controles y un procedimiento tampoco son documentos intercambiables. La organización selecciona referencias y las adapta a sus riesgos, responsabilidades y capacidad de operación.

3. Estructura y gobierno de una política

Una política necesita suficiente contexto para que dos personas interpreten de manera consistente qué les corresponde hacer. Un conjunto de prohibiciones sin alcance, responsables ni revisión deja decisiones esenciales sin resolver.

Parte	Contenido y sentido
Identificación	Nombre, código, versión y estado. Permite distinguir un borrador de la versión vigente.
Propósito	Objetivo de protección y riesgos que justifican la política.
Alcance	Personas, terceros, procesos, servicios, modalidades y exclusiones.
Definiciones	Significado de términos que podrían generar interpretaciones diferentes.
Roles	Autoridad para aprobar, autorizar accesos, implementar, verificar y decidir sobre el residual.
Requisitos	Obligaciones concretas y condiciones de cumplimiento.
Excepciones	Procedimiento para evaluar y autorizar desviaciones temporales.
Incumplimiento	Reporte, contención autorizada y seguimiento de las desviaciones.
Revisión	Frecuencia, responsables y acontecimientos que obligan a reevaluar el documento.
Aprobación e historial	Quién aprobó, desde cuándo rige y qué cambió respecto de la versión anterior.

Alcance y exclusiones

El acceso remoto puede incluir una VPN, administración de servidores, soporte de un tercero, correo en la nube o acceso a un portal desde fuera de las instalaciones. El alcance debe identificar cuáles de esas modalidades regula la política. «Aplica a los usuarios» deja abierta la situación de proveedores, administradores y cuentas técnicas.

Una exclusión debe expresar qué queda fuera y cómo se gestiona. Excluir equipos personales del acceso permitido es una decisión de protección; omitirlos del documento sin definir si pueden utilizarse produce una ambigüedad.

Responsabilidades y autoridad

El **propietario de la política** mantiene el documento y coordina su revisión. El **propietario del riesgo** responde por el escenario y sus consecuencias. El **responsable de implementar** configura o ejecuta el control. El **verificador** evalúa la evidencia. Estos roles pueden pertenecer a cargos distintos.

En PACÍFICO RETAIL, Tecnología puede configurar la protección del panel, mientras Gerencia comercial conserva la propiedad de R-03. Recursos Humanos participa en las bajas de R-01. Un proveedor puede ejecutar una tarea, pero la responsabilidad de decidir sobre el riesgo empresarial permanece en la organización.

4. De una intención a un requisito verificable

Un requisito es verificable cuando existe una forma razonable de determinar si se cumplió. Para ello necesita acción, objeto, alcance y una condición temporal; también debe permitir identificar al responsable y la evidencia.

```
Responsable + debe + acción y objeto + alcance o condición
            + plazo o frecuencia + evidencia de cumplimiento
```

«Proteger los accesos» expresa una intención amplia. «El responsable de identidades debe revisar mensualmente las cuentas remotas habilitadas, retirar las que no tengan autorización vigente y conservar el acta y el listado posterior» permite comprobar población, fecha, decisión y resultado.

Expresión inicial	Problema de interpretación	Obligación de ejemplo
Se recomienda MFA.	No establece obligatoriedad ni momento de aplicación.	Identidades debe exigir MFA a toda cuenta humana remota antes de habilitarla y conservar la configuración y las pruebas.
Los equipos deben ser seguros.	No define una condición de aceptación.	Tecnología debe comprobar cifrado de disco y protección activa en equipos gestionados antes del alta y en la revisión mensual.
Los proveedores acceden cuando sea necesario.	No identifica quién decide la necesidad ni cuándo termina.	El patrocinador debe aprobar servicios y ventana de acceso; Tecnología debe configurar la expiración y registrar la baja.

Un requisito completo y su validación

En el ejemplo ficticio de VIÑA DEL ESTE, un proveedor necesita soporte remoto temporal:

> El patrocinador interno debe solicitar una cuenta individual para cada técnico del proveedor, indicando servicios y vencimiento. Tecnología debe configurar la cuenta con los permisos aprobados y expiración antes de habilitarla, y conservar el ticket y la configuración. El patrocinador revisará mensualmente las cuentas de terceros vigentes.

La validación puede comparar solicitud, aprobación y configuración, y comprobar qué sucede al vencer una cuenta de prueba. Una entrevista al patrocinador ayuda a comprender el proceso, mientras los registros permiten corroborar su ejecución.

Los plazos y frecuencias deben responder al riesgo y a la capacidad de la organización. Los valores de los ejemplos son decisiones didácticas; no constituyen por sí solos un mandato de una ley o norma.

5. Controles de una política de acceso remoto

El **acceso remoto** permite utilizar recursos de una organización desde una ubicación externa a su entorno habitual. La protección requiere considerar conjuntamente identidad, dispositivo, canal, permisos y seguimiento: una condición adecuada en una de esas dimensiones no resuelve las restantes.

Identidad, autenticación y autorización

La **identificación** indica qué identidad solicita acceso. La **autenticación** comprueba el control de sus autenticadores. La **autorización** determina qué acciones y recursos puede utilizar esa identidad. Una cuenta autenticada puede carecer de permiso para administrar un servidor.

MFA utiliza factores de categorías distintas, como conocimiento de un secreto y posesión de un autenticador. Dos contraseñas siguen siendo factores de conocimiento. La cuenta individual y MFA cumplen propósitos complementarios: la primera permite atribuir actividad; el segundo refuerza la autenticación. NIST SP 800-63B-4.

El alta, recuperación y baja del autenticador también importan. Si una recuperación de acceso permite eludir los controles previstos, la protección del inicio de sesión queda incompleta. La política debe asignar responsabilidad sobre ese ciclo, además de exigir el mecanismo.

Dispositivo y canal

Un **equipo gestionado** está incorporado a los mecanismos de administración y comprobación de la organización. Eso permite verificar condiciones como actualización, protección activa y cifrado del almacenamiento. BYOD significa utilizar dispositivos personales; admitirlos exige definir condiciones y restricciones compatibles con su administración.

El cifrado del canal protege la comunicación entre sus extremos. El cifrado de disco protege datos almacenados bajo determinadas condiciones. Son controles diferentes: una sesión cifrada no demuestra que el equipo esté libre de software malicioso, y un disco cifrado no demuestra que el canal de acceso sea adecuado.

Origen, servicio, horario y privilegios

La autorización debe vincular una necesidad de trabajo con recursos concretos. Un técnico que mantiene un servicio no necesita por ese motivo acceso irrestricto a todas las bases de datos. El **mínimo privilegio** limita permisos a lo necesario; su revisión evita que se acumulen después de cambios de función.

La restricción por origen reduce los lugares desde los que se alcanza un servicio. La limitación por servicio reduce las funciones accesibles. Una ventana horaria acota cuándo se permite el acceso. Ninguna de estas condiciones identifica por sí sola a una persona: un equipo autorizado podría estar comprometido o ser utilizado por alguien sin permiso.

Terceros, bajas y cuentas técnicas

Cada tercero necesita patrocinador interno, propósito, alcance y vencimiento. El cierre debe contemplar cuentas, credenciales y sesiones o permisos persistentes según el servicio. Un contrato vencido y una cuenta activa son estados que necesitan conciliarse.

Las cuentas de servicio permiten tareas automáticas. Su control requiere propietario, finalidad, privilegios limitados y protección de secretos. No conviene tratarlas como personas ni utilizarlas como cuentas humanas compartidas. En R-06, la concentración de permisos de `svc_backup` sobre sitio y respaldos también exige revisar el alcance de privilegios y la evidencia de uso.

6. Implementación y métricas de cumplimiento

Implementar una política significa hacer operativas sus obligaciones. Incluye aprobación, recursos, configuración, comunicación, capacitación, verificación y seguimiento. La publicación de un archivo acredita disponibilidad del documento, pero no que las personas lo comprendan o que los controles funcionen.

Fase	Resultado esperado	Evidencia posible
Aprobar	Autoridad y alcance definidos.	Versión aprobada y fecha de vigencia.
Preparar	Responsables, dependencias y recursos disponibles.	Plan de cambio, inventario y reversión prevista.
Comunicar y capacitar	Las personas conocen obligaciones y saben aplicarlas.	Destinatarios, participación y comprobación de comprensión.
Configurar	Los mecanismos aplican los requisitos.	Configuraciones, autorizaciones y registros de cambio.
Validar	Se conoce el resultado de las comprobaciones.	Pruebas, muestras y resultados observados.
Dar seguimiento	Las desviaciones tienen tratamiento y revisión.	Métricas, acciones y confirmaciones de cierre.

La aceptación de lectura deja constancia de que una persona recibió una versión y reconoce sus obligaciones. La aceptación del riesgo residual corresponde al propietario con autoridad y considera evidencia y tolerancias. Una firma de lectura no equivale a esa decisión.

Qué debe definir una métrica

Una métrica convierte registros en información para decidir. Necesita población, fórmula o conteo, período o fecha de corte, fuente, responsable, frecuencia, meta y respuesta ante desviaciones. Sin esos elementos, dos informes con el mismo nombre pueden medir cosas distintas.

Métrica	Cálculo de ejemplo	Fuente necesaria
Cobertura MFA	Cuentas humanas remotas activas con MFA obligatorio / total de cuentas humanas remotas activas × 100.	Inventario conciliado con configuración del servicio de identidad.
Cuentas inactivas	Conteo de cuentas remotas habilitadas sin uso por más del umbral definido.	Estado de cuentas y registro del último acceso.
Revisiones realizadas	Revisiones completadas con evidencia / revisiones programadas en el período × 100.	Calendario de revisiones y actas.
Excepciones vencidas	Conteo de excepciones abiertas cuyo vencimiento es anterior a la fecha de corte.	Registro de excepciones y estado de cierre.

Ejemplo de cálculo e interpretación

Una organización ficticia tiene 20 cuentas humanas remotas activas; 18 están sujetas a MFA obligatorio. La cobertura es `18 / 20 × 100 = 90 %`. Si otras dos cuentas tienen MFA disponible, pero opcional, no se cuentan como cubiertas por el requisito obligatorio.

Si había cuatro revisiones programadas y tres se completaron con acta, el cumplimiento del período es `3 / 4 × 100 = 75 %`. Una cuarta reunión sin evidencia suficiente no acredita por sí sola la revisión completa.

El 90 % de cobertura no significa «90 % de seguridad». La métrica muestra dos cuentas sin cobertura y no mide otros aspectos, como el estado del dispositivo o la calidad de las autorizaciones. Ante un denominador cero, corresponde informar que el porcentaje no aplica y explicar la población, en lugar de presentar 0 % o 100 % sin sentido.

Para comparar períodos debe mantenerse la definición o documentar su cambio. Si se excluyen cuentas del denominador sin explicarlo, una mejora aparente puede ocultar una brecha real.

7. Validación y auditoría de controles

La **validación** comprueba si un requisito o resultado definido se satisface en condiciones determinadas. Una **auditoría** organiza la evaluación frente a criterios explícitos y documenta alcance, evidencia y conclusiones. La diferencia no reside en utilizar una herramienta más compleja: reside en la pregunta, el criterio y la trazabilidad de la evaluación.

Los criterios pueden proceder de una política aprobada, una obligación contractual o una configuración interna obligatoria. La evaluación debe identificar qué versión y período utiliza. Comparar un registro antiguo con una política posterior puede llevar a una conclusión injustificada si no se aclara la vigencia de cada uno.

Examinar, entrevistar y probar

NIST SP 800-53A distingue tres métodos que pueden combinarse según el objetivo de evaluación. NIST SP 800-53A Rev. 5.

Método	En qué consiste	Ejemplo de acceso remoto
Examinar	Revisar documentos, mecanismos o registros pertinentes.	Comparar autorizaciones, cuentas habilitadas y configuración de expiración.
Entrevistar	Obtener explicaciones de quienes realizan o supervisan una actividad.	Preguntar al patrocinador cómo confirma que un tercero aún necesita acceso.
Probar	Ejercitar un mecanismo bajo condiciones definidas y observar su comportamiento.	Comprobar acceso permitido desde administración y rechazado desde un origen no autorizado.

Cada método aporta un tipo de evidencia. Un documento puede mostrar el diseño; una entrevista explica cómo se interpreta; una prueba observa un comportamiento. La combinación permite encontrar diferencias entre lo aprobado, lo configurado y lo que sucede.

Por ejemplo, un patrocinador puede afirmar que todas las cuentas vencen al finalizar el contrato. Si la configuración conserva una cuenta sin expiración, la declaración no acredita cumplimiento. La discrepancia debe investigarse con la autorización y el estado de esa cuenta.

Diseño y operación

La evaluación del **diseño** pregunta si el control, ejecutado como está definido, podría satisfacer el requisito. La evaluación de **operación** pregunta si efectivamente se ejecuta con la cobertura y frecuencia previstas.

Un proceso que retira cuentas solo cuando alguien recuerda enviar un correo tiene una debilidad de diseño. Un proceso con aviso, plazo y conciliación puede estar bien diseñado y, aun así, incumplirse en la práctica. Para evaluar operación hacen falta casos y registros del período correspondiente.

Población y muestra

La **población** es el conjunto sobre el que se quiere concluir: todas las cuentas remotas activas a una fecha, todas las bajas del mes o todos los cambios de firewall del trimestre. La **muestra** es el subconjunto evaluado.

Una muestra debe indicar cuántos elementos incluye, cómo se seleccionaron y qué parte de la población representan. Revisar tres cuentas privilegiadas puede ser útil para investigar los accesos de mayor impacto, pero no permite afirmar sin más que todas las cuentas de la empresa cumplen.

La fecha también forma parte del alcance. Una prueba satisfactoria demuestra un resultado en ese momento y bajo esas condiciones. Para afirmar operación sostenida se necesita evidencia distribuida en un período adecuado.

La ficha de evaluación

Campo	Función
Requisito y criterio	Identificar qué debe cumplirse y la referencia aplicable.
Método	Explicar si se examina, entrevista, prueba o combina métodos.
Población y muestra	Delimitar sobre qué elementos se observará el resultado.
Procedimiento	Describir una comprobación que otra persona pueda entender y repetir.
Resultado esperado	Establecer antes de evaluar qué condición acredita cumplimiento.
Evidencia y observado	Registrar fuente, fecha y resultado real.
Conclusión y límite	Indicar cumplimiento, desviación, insuficiencia o no ejecución y hasta dónde alcanza lo observado.

El resultado esperado pertenece al diseño de la evaluación; el observado pertenece a su ejecución. Si todavía no se realizó, el estado es **no ejecutado**, aunque el procedimiento esté bien definido.

8. Fundamento técnico de la restricción SSH

SSH es un protocolo para establecer sesiones remotas protegidas, utilizado habitualmente en la administración de servidores. Su puerto convencional es TCP/22. Que una conexión llegue al servicio, que una persona pueda autenticarse y que tenga autorización para administrar son comprobaciones diferentes.

Un firewall filtra tráfico según condiciones como origen, destino, protocolo y puerto. Una regla que permite TCP/22 desde cualquier origen expone el servicio a un conjunto mayor de equipos que una regla limitada a una red administrativa.

Regla general y regla específica

La configuración de la maqueta utiliza una política de entrada denegada por defecto y permisos explícitos. Bajo ese esquema, una regla `allow 22/tcp` permite llegar a SSH desde cualquier origen cubierto por ella. Añadir además un permiso para `10.10.10.0/24` no convierte el permiso general en una restricción: mientras siga presente la regla amplia, otros orígenes continúan autorizados.

La corrección debe contemplar el conjunto de reglas y la política por defecto. Una lista de permisos aparentemente precisa puede convivir con otra excepción que invalide el resultado deseado. La documentación de Ubuntu explica el uso de UFW y sus reglas por origen y servicio. Firewall de Ubuntu Server.

Elemento de la maqueta	Significado
`10.10.10.0/24`	Subred desde la que se autoriza alcanzar SSH.
`10.20.20.0/24`	Subred desde la que se espera impedir ese acceso.
TCP/22	Servicio administrativo objeto de la prueba.
TCP/443	Permiso que debe conservarse al corregir la regla de SSH.
Entrada denegada por defecto	El tráfico entrante sin permiso aplicable se deniega.

La misma red interna de VirtualBox transporta ambas subredes IP. Esto permite observar filtrado por origen, pero no demuestra separación mediante VLAN ni reproduce una arquitectura empresarial completa.

Prueba positiva y prueba negativa

Una prueba positiva comprueba que una operación autorizada funciona. Una negativa comprueba que una operación fuera de autorización se rechaza. Se necesitan ambas porque impedir todos los accesos podría bloquear el trabajo legítimo sin satisfacer el requisito completo.

Resultado observado	Qué permite sostener
Aparece una petición de contraseña.	La conexión alcanzó la fase de autenticación del servicio. No acredita un inicio de sesión exitoso.
Se inicia sesión desde el origen permitido.	Esa combinación de origen, destino, servicio e identidad funcionó en la prueba.
La conexión agota el tiempo desde el origen restringido.	No se completó en el tiempo observado. La causa todavía necesita corroboración.
Un registro de bloqueo coincide con la prueba.	Aporta evidencia para atribuir el rechazo al firewall.

El tiempo agotado también puede deberse a un problema de ruta, un servidor detenido o un servicio sin respuesta. La atribución requiere correlacionar hora, IP de origen, IP de destino, protocolo y puerto con el evento de bloqueo.

`ufw status numbered` enumera reglas; `ufw status verbose` informa además la política por defecto. Ambas salidas aportan información distinta. Un registro `UFW BLOCK` de otro puerto o de una hora anterior no explica necesariamente la prueba evaluada.

Conservar un permiso TCP/443 acredita la configuración de firewall, pero no demuestra que haya una aplicación HTTPS operativa. Del mismo modo, una prueba SSH satisfactoria no acredita MFA, cifrado del disco ni correcta gestión de bajas.

9. Hallazgos, corrección y cierre

Un hallazgo de evaluación relaciona un **criterio** con una **condición observada**, respaldada por evidencia. Cuando existe una diferencia relevante, se describe la desviación, su efecto y el tratamiento necesario. Una frase como «el firewall está mal» no explica qué obligación se incumple ni qué evidencia lo demuestra.

```
Criterio: solo la red administrativa debe alcanzar SSH.
Condición: existe un permiso TCP/22 para cualquier origen.
Evidencia: configuración y conexión desde una subred no autorizada.
Efecto: el servicio queda alcanzable desde más orígenes que los aprobados.
```

Corrección y acción correctiva

La **corrección** resuelve la desviación detectada: retirar la regla amplia y comprobar el resultado. La **acción correctiva** trata su causa para reducir la repetición: por ejemplo, exigir revisión cruzada de cambios y pruebas de

ambos orígenes antes de aprobar una configuración.

Si una cuenta vencida sigue habilitada, suspenderla corrige el caso. Investigar por qué no se configuró expiración y mejorar la conciliación de contratos y cuentas actúa sobre la causa. Una causa supuesta debe investigarse; no se presenta como confirmada únicamente porque resulte plausible.

Criterio de cierre

El criterio de cierre se define antes de implementar la acción. Indica qué resultado permitirá considerar resuelta la desviación, quién lo verificará y qué evidencia conservará.

Componente	Ejemplo
Acción y responsable	El administrador retira el permiso amplio y conserva la configuración requerida.
Plazo	Antes de volver a habilitar el servicio bajo la nueva condición.
Verificación	Otra persona revisa reglas y resultados positivo y negativo.
Evidencia	Configuración final, pruebas identificadas y registro correlacionado.
Pendiente	Si falta atribución del bloqueo, se registra la incertidumbre y el paso para resolverla.

El cierre de una desviación técnica y la decisión sobre el riesgo empresarial ocurren en niveles distintos. LAB11-SSH identifica una condición preparada en un laboratorio; H-01 corresponde al panel web del caso. Corregir el laboratorio no demuestra que el panel real esté protegido ni autoriza reducir R-03 sin evidencia de ese entorno.

10. Requisitos de desarrollo seguro del portal

La seguridad de un portal también depende de las decisiones tomadas al analizar necesidades, diseñar componentes, escribir código y verificar cambios. Introducir requisitos desde el diseño permite asociar cada riesgo con una medida y una forma de comprobarla, en lugar de esperar a encontrar fallas cuando el servicio ya está publicado.

OWASP ASVS aporta requisitos de verificación de aplicaciones. NIST SSDF organiza prácticas del desarrollo seguro. Sus funciones se complementan: una referencia puede especificar una propiedad que debe tener la aplicación y otra orientar el proceso para producir y revisar esa propiedad.

Las referencias siguientes fijan **ASVS 5.0.0** y **SSDF 1.1**. Las síntesis son adaptaciones explicativas en español; los enlaces permiten consultar el texto original. Los códigos D-01, D-02, C-01 y C-02 identifican los cuatro extractos utilizados en la actividad.

D-01 · Analizar amenazas antes de aprobar el diseño

Referencia: SSDF 1.1, tarea PW.1.1. El modelado de riesgos ayuda a identificar amenazas y orientar mitigaciones de diseño. En un portal, supone estudiar qué información circula, quién puede actuar sobre ella y dónde podría romperse una condición de confianza.

Por ejemplo, conocer el identificador de un pedido no debería bastar para consultar los datos de otra persona. El análisis puede conducir a un requisito de autorización por propietario del pedido. La evidencia de diseño sería el modelo, la decisión adoptada y su revisión.

Fuente: NIST SP 800-218, PW.1.1, página 11 impresa.

D-02 · Documentar autorizaciones por función y dato

Referencia: ASVS 5.0.0, v5.0.0-8.1.1. Las reglas deben expresar qué funciones y datos puede utilizar cada identidad según sus permisos y los atributos del recurso. «Usuario autenticado» suele ser una condición insuficiente para definir ese alcance.

Una matriz puede distinguir las funciones de cliente, Comercial y soporte, y precisar qué pedidos, precios o datos corresponden a cada uno. Esa definición sirve de base para implementar y probar permisos coherentes.

Fuente: OWASP ASVS 5.0.0, V8, autorización.

C-01 · Proteger las consultas frente a inyección

Referencia: ASVS 5.0.0, v5.0.0-1.2.4. La parametrización y otros mecanismos adecuados protegen las consultas al separar los valores recibidos de su estructura. Si una aplicación construye instrucciones concatenando datos no confiables, puede interpretar parte de esos datos como instrucciones.

La revisión de código debe comprobar cómo se construyen las consultas y las pruebas deben cubrir los casos relevantes. La validación de formato de un campo es una defensa complementaria, pero no acredita por sí sola una construcción segura de consultas.

Fuente: OWASP ASVS 5.0.0, V1, prevención de inyección.

C-02 · Revisar código y dar seguimiento a los problemas

Referencia: SSDF 1.1, tarea PW.7.2. La revisión o análisis del código debe relacionarse con el estándar de codificación segura y registrar los problemas, su prioridad y las acciones necesarias.

El informe de una herramienta es una entrada para decidir. El seguimiento necesita responsable, estado y evidencia de resolución o tratamiento. Así puede comprobarse qué observaciones se atendieron antes de liberar un cambio y cuáles permanecen pendientes.

Fuente: NIST SP 800-218, PW.7.2, página 14 impresa.

Convertir la referencia en una obligación

Un requisito organizacional agrega contexto, responsable, momento y evidencia. Por ejemplo: «El equipo de arquitectura debe aprobar las reglas de autorización por función y tipo de dato antes de comenzar el desarrollo, y conservar la matriz y el acta de revisión».

Los requisitos del ciclo de desarrollo pueden documentarse en un anexo específico porque regulan decisiones distintas del acceso remoto de personas y terceros. Ambos conjuntos comparten la trazabilidad riesgo-requisito-control-evidencia.

11. Excepciones y controles compensatorios

Una **excepción** es una desviación de un requisito, autorizada con alcance y duración limitados. Puede ser necesaria cuando un servicio no soporta todavía el mecanismo previsto o una reparación requiere una ventana extraordinaria. Su gestión debe impedir que una necesidad temporal se convierta en un permiso indefinido.

Campo	Razón para registrarlo
Requisito afectado	Determina exactamente qué condición se aparta de la política.
Solicitante y justificación	Explica la necesidad operativa y las alternativas consideradas.
Riesgo y alcance	Identifica qué exposición se admite, sobre qué recursos y personas.
Aprobador	Permite comprobar que decide alguien con autoridad suficiente.
Inicio y vencimiento	Establece la duración de la autorización.
Compensatorio	Define una protección temporal y cómo se comprueba.
Responsable y revisión	Asigna quién supervisa el permiso y cuándo evalúa su continuidad.
Cierre	Acredita retiro de la desviación o decisión posterior expresamente autorizada.

Un control compensatorio puede limitar orígenes, servicios o duración, agregar supervisión o aumentar monitoreo. Su utilidad depende del escenario. Observar más registros podría facilitar detección, pero no produce el mismo efecto que impedir el acceso: la diferencia debe reconocerse al evaluar el residual.

Por ejemplo, un proveedor requiere una conexión fuera del horario habitual. La excepción puede limitarse a una cuenta individual, un servidor y dos horas, con supervisión y revocación al finalizar. Una autorización que dice «mientras sea necesario» carece de un vencimiento verificable.

La excepción de política, la autorización de un cambio y la aceptación del riesgo residual se relacionan, pero resuelven preguntas distintas. Autorizar una conexión fuera de horario no implica autorizar cualquier modificación de producción. Tampoco una excepción interna modifica por sí sola una obligación externa aplicable.

12. Versiones, revisión y mejora continua

El control de versiones permite saber cuál es la obligación vigente y reconstruir decisiones anteriores. Debe conservar identificación, estado, autor o responsable, aprobador, fecha de vigencia y resumen de cambios. La revisión evalúa si el documento sigue siendo adecuado; puede confirmar la versión o producir una modificación.

Disparador de revisión	Aspecto que conviene reevaluar
Incidente o acceso indebido	Si las obligaciones, controles y verificaciones cubrían el escenario.
Nuevo proveedor o servicio	Si cambian responsabilidades, flujos y evidencias disponibles.
Cambio de tecnología	Si los mecanismos aplican todavía los requisitos.
Excepciones repetidas	Si existe una dificultad estructural de diseño, recursos o implementación.
Desviaciones persistentes	Si falta capacitación, supervisión o una acción sobre la causa.

Disparador de revisión	Aspecto que conviene reevaluar
Fecha de revisión periódica	Si alcance, riesgos y requisitos conservan vigencia.

Comunicar una versión nueva implica identificar a las personas afectadas y explicar qué cambia. Si se modifica el mecanismo de acceso, puede ser necesaria capacitación adicional. Conservar solo una firma antigua no demuestra que se haya comunicado la nueva obligación.

El seguimiento completa el ciclo: las métricas y evaluaciones aportan evidencia, los responsables corrigen las desviaciones y el propietario reconsidera lo que permanece. Un documento sin revisión puede seguir formalmente publicado mientras deja de representar la operación real.



13. Ejemplo resuelto: acceso remoto en VIÑA DEL ESTE

En la lección 10, VIÑA DEL ESTE tenía un escenario de uso de credenciales robadas para enviar órdenes falsas desde el correo. La propuesta era deshabilitar autenticación heredada y exigir MFA, con una alerta temporal mientras se completaba el despliegue. Ese plan se utiliza aquí para desarrollar una política y su evaluación. Los datos siguientes amplían el ejemplo ficticio; no corresponden a resultados de PACÍFICO RETAIL.

Del tratamiento al requisito

Propósito: reducir el acceso indebido al correo corporativo y mejorar la atribución de actividad. **Alcance:** cuentas humanas con acceso remoto al correo, incluidos terceros autorizados. Las identidades automáticas se gestionan mediante requisitos específicos de servicio.

Propietario de la política: Jefatura de TI. **Aprobador propuesto:** Gerencia de operaciones. La versión permanece como borrador hasta su aprobación; la vigencia se registra junto con el plan de despliegue.

ID	Requisito de ejemplo	Evidencia prevista
VE-01	Identidades debe habilitar acceso humano remoto únicamente mediante cuenta individual con MFA obligatorio y autenticación heredada deshabilitada; comprobarlo antes del alta y semanalmente.	Inventario conciliado, configuración y pruebas de ambas condiciones.
VE-02	El patrocinador de cada tercero debe aprobar finalidad, permisos y vencimiento; Identidades debe aplicar la expiración antes del alta.	Solicitud aprobada, fecha contractual y configuración.
VE-03	TI debe suspender cuentas al finalizar la autorización y conciliar semanalmente las bajas con el registro de personas y terceros.	Aviso, estado de cuenta y acta de conciliación.
VE-04	Seguridad debe revisar alertas de acceso cada día hábil y registrar investigación, responsable y tratamiento de los eventos relevantes.	Alertas y registro de revisión con decisiones.

Las frecuencias son valores propuestos para este ejemplo. Su aprobación debe considerar recursos, criticidad y obligaciones de la organización.

Implementación y aceptación

El despliegue comienza con aprobación y comunicación. TI prepara el inventario, identifica dependencias y establece cómo recuperar acceso si una configuración interrumpe una operación legítima. Después configura MFA y el bloqueo del mecanismo heredado, y ejecuta validaciones antes de declarar terminada la acción.

La alerta temporal definida en L10 conserva responsable y vencimiento. Su existencia no acredita que el control principal haya quedado implementado. Si una aplicación depende del mecanismo heredado, se documenta la brecha y se decide su tratamiento; no se elimina silenciosamente esa cuenta del alcance de medición.

Ficha de evaluación resuelta

Campo	Desarrollo de VE-01
Criterio	Todas las cuentas humanas remotas tienen MFA obligatorio y autenticación heredada deshabilitada.
Población	Las 20 cuentas humanas remotas habilitadas al corte del ejemplo.
Métodos	Examinar inventario y configuración; probar los mecanismos en cuentas de prueba autorizadas.
Procedimiento	Conciliar las 20 cuentas, revisar aplicación de la política y comprobar acceso mediante la vía aprobada y rechazo del mecanismo heredado.
Esperado	Cobertura de las 20 cuentas y comportamiento coherente con ambas restricciones.
Observado ficticio	18 cuentas cubiertas; dos conservan el acceso heredado. Las cuentas de prueba cubiertas funcionan como se esperaba.
Conclusión	VE-01 no cumple en toda la población. Las pruebas favorables en cuentas cubiertas no subsanan las dos brechas.
Límite	No se demuestra protección de los dispositivos ni operación durante un período mayor al revisado.

Desviación y acción

El hallazgo identifica dos cuentas sin cobertura, con evidencia de configuración al corte. La corrección consiste en aplicar el requisito a esas cuentas mediante un cambio autorizado y volver a comprobar su estado. TI ejecuta; Seguridad verifica. El plazo se fija antes del uso operativo que requiera la cobertura completa o se escala una excepción temporal con compensatorio y vencimiento.

La acción para evitar repetición incorpora la conciliación del inventario con la configuración obligatoria en cada alta y revisión semanal. Cerrar el ticket exige evidencia de las dos cuentas corregidas y repetición de las comprobaciones pertinentes.

Decisión sobre el residual

Mientras existan las dos brechas, no se acredita la meta de cobertura total que sustentaba la reducción esperada en L10. Tras corregirlas, la nueva evidencia permite reevaluar la probabilidad, la confianza y el residual. La consecuencia potencial de una orden falsa no desaparece automáticamente por habilitar MFA.

Gerencia de operaciones decide si el residual queda dentro de su tolerancia y autoridad, si requiere otra acción o si debe escalarse. La conclusión conserva la fecha de revisión y los hechos que podrían reabrir la decisión.

14. Calidad de evidencia y alcance de las conclusiones

La evidencia debe ser pertinente para la pregunta, suficientemente completa y ubicable en un contexto. Su calidad depende de la fuente, la fecha, la población y la posibilidad de relacionarla con el control evaluado.

Evidencia disponible	Conclusión que requiere más respaldo
Política firmada	Que todas las personas la conocen y la aplican.
Captura de MFA en una cuenta	Que todas las cuentas remotas están cubiertas.
Explicación verbal de una baja	Que la cuenta efectivamente quedó suspendida dentro del plazo.
Regla de firewall correcta	Que el tráfico observado siguió esa ruta y fue tratado como se esperaba.
Prueba satisfactoria de un día	Que el control operó de forma sostenida durante meses.

La corroboración utiliza fuentes que responden a aspectos distintos de la misma afirmación. Un ticket muestra autorización; la configuración muestra un estado técnico; un registro de ejecución y una prueba muestran comportamiento. Repetir la misma captura en varios documentos no añade corroboración.

La conservación de evidencia debe permitir identificar origen, fecha, responsable y requisito relacionado, protegiendo credenciales y datos que no sean necesarios para la evaluación. Un extracto contextualizado puede ser suficiente; un volumen grande de registros sin interpretación dificulta comprender el resultado.

Cuando falta información, la conclusión puede ser **evidencia insuficiente**. Eso expresa el límite del conocimiento disponible, no un cumplimiento implícito ni una demostración automática de incumplimiento técnico. La diferencia es la misma que en L10 entre una condición confirmada y un hallazgo pendiente de validación.

15. Cómo se relacionan las referencias de seguridad

Las referencias aportan criterios de distinto nivel. Su selección debe partir del problema que se quiere resolver.

Referencia	Aporte a la gestión
ISO/IEC 27001	Requisitos para establecer y mejorar un sistema de gestión de seguridad dentro de un alcance.
NIST CSF 2.0	Resultados de ciberseguridad que ayudan a organizar responsabilidades, prioridades y brechas entre situación actual y objetivo.
NIST SP 800-53	Catálogo de controles que puede adaptarse a necesidades de acceso, cuentas, autenticación y registros.
NIST SP 800-53A	Procedimientos y métodos para evaluar controles.
OWASP ASVS	Requisitos de verificación de seguridad de aplicaciones.
NIST SSDF	Prácticas para integrar seguridad al ciclo de desarrollo de software.

En CSF, el gobierno de políticas y responsabilidades se vincula con GOVERN; la gestión de identidades y acceso, con PROTECT. La correspondencia ayuda a ubicar el trabajo dentro de una gestión más amplia. No implica que una sola política cubra todo el marco.

Citar AC-17 del catálogo NIST para acceso remoto permite identificar una referencia, pero la evidencia sigue siendo necesaria para sostener una conclusión sobre el control aplicado. Del mismo modo, seleccionar dos requisitos ASVS no demuestra conformidad con el estándar completo. NIST SP 800-53 y NIST CSF 2.0.

16. Preguntas de repaso

1. ¿Qué relación existe entre tratamiento, política, control y evidencia?
2. ¿Qué diferencia hay entre una política, un estándar técnico interno y un procedimiento?
3. ¿Por qué alcance, aprobación y vigencia son necesarios para evaluar una obligación?
4. ¿Qué elementos permiten convertir «acceso seguro» en un requisito verificable?
5. ¿Qué diferencias existen entre autenticación, autorización y mínimo privilegio?
6. ¿Por qué una cuenta individual y MFA cumplen funciones complementarias?
7. ¿Qué requiere el tratamiento de una cuenta técnica frente al de una cuenta humana?
8. ¿Cómo se distinguen comunicación, capacitación y aceptación de lectura?
9. ¿Qué fuentes y población se necesitan para calcular cobertura MFA?
10. ¿Por qué una mejora del porcentaje podría ocultar una brecha si cambia el denominador?
11. ¿Qué aporta cada método: examinar, entrevistar y probar?
12. ¿Qué limita una conclusión basada en una muestra o una única prueba?
13. ¿Por qué un permiso específico de SSH no corrige una regla general que continúa activa?
14. ¿Qué demuestra una petición de contraseña? ¿Qué demuestra un tiempo agotado?
15. ¿Cómo se diferencian corrección, acción correctiva y aceptación del riesgo residual?
16. ¿Qué información impide que una excepción temporal se vuelva permanente?
17. ¿Cómo se transforma una referencia ASVS o SSDF en un requisito organizacional?
18. ¿Qué evidencia adicional necesitaría VIÑA DEL ESTE para revisar su residual después de corregir las dos cuentas?

17. Glosario

Término	Definición
Acción correctiva	Acción dirigida a la causa de una desviación para reducir su repetición.
Alcance	Personas, procesos, recursos, condiciones y período a los que se aplica un documento o evaluación.
Autenticación	Comprobación del control de autenticadores asociados a una identidad.
Autorización	Determinación de las acciones y recursos permitidos a una identidad.
BYOD	Uso de dispositivos personales para acceder a recursos de la organización.
Control compensatorio	Protección alternativa o temporal cuya contribución al riesgo debe evaluarse.
Corrección	Acción que resuelve una desviación concreta detectada.
Criterio de cierre	Condición verificable que debe satisfacerse para dar por resuelta una acción o desviación.
Evidencia	Información pertinente que respalda una evaluación o conclusión.
Excepción	Desviación autorizada de un requisito con alcance, condiciones y duración definidos.

Término	Definición
MFA	Autenticación que utiliza factores de categorías distintas.
Mínimo privilegio	Limitación de permisos a los necesarios para una función autorizada.
Muestra	Subconjunto de la población seleccionado para una evaluación.
Población	Conjunto de elementos sobre el que se quiere evaluar o medir una condición.
Política	Decisiones y obligaciones aprobadas que orientan y exigen conductas y controles.
Propietario del riesgo	Cargo con responsabilidad y autoridad sobre el escenario y su tratamiento.
Requisito verificable	Obligación cuyo cumplimiento puede evaluarse con criterios y evidencia definidos.
Residual actual	Riesgo que permanece considerando los controles cuya operación se ha acreditado.
Residual esperado	Meta de riesgo condicionada a implementar y verificar el tratamiento.
Trazabilidad	Posibilidad de seguir la relación entre riesgo, requisito, control, evidencia y decisión.

Fuentes de consulta y profundización

- ISO/IEC 27001:2022: alcance del sistema de gestión y referencia para gobierno, documentación y mejora. La ficha pública no sustituye el texto íntegro del estándar.
- NIST SP 800-46 Rev. 2: acceso remoto, teletrabajo y dispositivos personales.
- NIST SP 800-63B-4: autenticación digital y ciclo de los autenticadores.
- NIST SP 800-53 Rev. 5: controles de acceso remoto, cuentas, identificación y registros; consultar AC-17, AC-2 y las familias IA y AU.
- NIST SP 800-53A Rev. 5: fundamentos y procedimientos de evaluación de controles.
- NIST CSF 2.0: gobierno, protección y relación entre resultados actuales y objetivos.
- OWASP ASVS 5.0.0: profundización en documentación de autorización y prevención de inyección.
- NIST SSDF 1.1, SP 800-218: diseño seguro y revisión de código, especialmente PW.1.1 y PW.7.2.
- Firewall de Ubuntu Server: comportamiento y configuración de UFW.

Referencias consultadas el 18 de octubre de 2026. Los ejemplos y sus metas, frecuencias y plazos son ilustrativos; su aplicación organizacional requiere definición y aprobación dentro del contexto correspondiente.